Botium Toys: Internal Security Audit

Controls assessment, compliance review and remediation plan

Type	Internal IT security audit (case study)
Frameworks	NIST Cybersecurity Framework (CSF), PCI DSS, GDPR, SOC 1 / SOC 2
Skills	Asset and risk assessment, control evaluation, compliance mapping, writing recommendations for stakeholders
Source	Google Cybersecurity Professional Certificate, Course 2 (*Play It Safe: Manage Security Risks*)

Summary

Botium Toys is a small U.S. toy retailer with a physical store, a warehouse and a growing online store that takes card payments and serves E.U. customers. I reviewed the company's whole security program against a standard list of controls and against three compliance regimes (PCI DSS, GDPR and SOC 1/2).

Overall risk score: 8 / 10 (high). The company has decent physical security and basic perimeter defences (firewall, antivirus). It is missing most of the controls that protect cardholder data and customer PII: **access is not restricted, data is not encrypted, there are no backups or disaster recovery plan, and there is no intrusion detection.** As things stand, Botium Toys is **not compliant with PCI DSS** and is only partly aligned with GDPR and SOC 2.

Scope and goals

- **Scope:** The entire security program, including all IT-managed assets and the internal processes for implementing controls and meeting compliance requirements.
- **Goal:** Assess current assets, complete the controls and compliance checklist, and recommend which controls and practices Botium Toys should implement to improve its security posture.

Assets in scope: on-premises office equipment; employee devices (desktops, laptops, smartphones, remote workstations and peripherals); storefront and warehouse inventory; business systems (accounting, telecoms, database, e-commerce, inventory management); internet access; the internal network; data retention and storage; and end-of-life legacy systems.

Controls assessment

Question: Does Botium Toys currently have this control in place?

Control	Category / type	In place?	Evidence from audit
Least privilege	Administrative / preventive	**No**	All employees can access internal data,

Control	Category / type	In place?	Evidence from audit
			including cardholder data and PII/SPII
Disaster recovery plans	Administrative / corrective	**No**	No DR plan exists
Password policies	Administrative / preventive	**No**	A policy exists, but its requirements are nominal and don't meet current standards
Separation of duties	Administrative / preventive	**No**	Not implemented
Firewall	Technical / preventive	Yes	Blocks traffic using a defined rule set
Intrusion detection system (IDS)	Technical / detective	**No**	No IDS installed
Backups	Technical / corrective	**No**	No backups of critical data
Antivirus software	Technical / corrective	Yes	Installed and monitored by IT
Manual monitoring, maintenance and intervention for legacy systems	Technical / preventive	**No**	Systems are monitored, but there's no schedule and no defined intervention process
Encryption	Technical / deterrent	**No**	Card data is stored and processed unencrypted
Password management system	Technical / preventive	**No**	No central password management; resets go through IT tickets
Locks (offices, storefront, warehouse)	Physical / preventive	Yes	Sufficient locks in place
CCTV surveillance	Physical / preventive, detective	Yes	Up-to-date CCTV
Fire detection and prevention	Physical / detective, preventive	Yes	Fire alarm and sprinkler systems working

Compliance assessment

Question: Does Botium Toys currently follow this compliance best practice?

PCI DSS (Payment Card Industry Data Security Standard)

Best practice	Adheres?	Why
Only authorised users have access to customers' credit card information	**No**	All employees can access internal data

Best practice	Adheres?	Why
Credit card information is stored, accepted, processed and transmitted internally in a secure environment	**No**	Card data is unencrypted and access is not restricted
Implement data encryption to secure card transaction touchpoints and data	**No**	No encryption is in use
Adopt secure password management policies	**No**	The password policy is weak and there's no password manager

GDPR (General Data Protection Regulation)

Best practice	Adheres?	Why
E.U. customers' data is kept private and secured	**No**	No encryption or access control on customer data
A plan exists to notify E.U. customers within 72 hours of a breach	Yes	A 72-hour notification plan is in place
Data is properly classified and inventoried	**No**	Assets have not been inventoried or classified
Privacy policies, procedures and processes are enforced to document and maintain data	Yes	Privacy policies have been developed and are enforced

SOC 1 / SOC 2 (System and Organization Controls)

Best practice	Adheres?	Why
User access policies are established	**No**	No least privilege or separation of duties
Sensitive data (PII/SPII) is kept confidential and private	**No**	All employees can access it, and it is unencrypted
Data integrity: data is consistent, complete, accurate and validated	Yes	IT has integrity controls in place
Data is available to individuals authorised to access it	Yes	IT ensures availability

Recommendations

Listed in priority order, with the NIST CSF function each one supports.

Priority 1: protect cardholder data and PII (needed for PCI DSS and GDPR)

1. **Put least privilege and separation of duties in place** *(Protect)*. Use role-based access so only staff who need it can reach cardholder data and PII. Separate the duties for payment processing, refunds and system administration.
2. **Encrypt cardholder data and PII** *(Protect)*, both at rest in the internal database and in transit (TLS) at every payment touchpoint.

3. **Create a data inventory and classification scheme** *(Identify)* so the company knows where sensitive data lives and can apply controls in proportion to the risk.

Priority 2: detect and recover

4. **Deploy an IDS/IPS** *(Detect)* and send its alerts, along with firewall and antivirus logs, to one place where IT reviews them.
5. **Set up regular backups and a written disaster recovery plan** *(Recover)*. Follow the 3-2-1 backup rule, test restores and set recovery-time objectives for the e-commerce and inventory systems.

Priority 3: strengthen identity and legacy systems

6. **Update the password policy to current NIST SP 800-63B guidance** *(Protect)*: favour length over complexity rules, block known-breached passwords and stop forcing scheduled password changes. Back the policy with a **central password manager** and **multi-factor authentication**. This also cuts down on password-reset tickets.
7. **Set a schedule for maintaining legacy systems** *(Identify / Protect)*, with defined intervention steps, and plan their replacement.

Keep doing: firewall rule maintenance, antivirus monitoring, the physical security controls and the 72-hour GDPR breach-notification plan.

Reflection

This audit showed me that compliance gaps usually come down to a few missing basics. Here, just two controls (access control and encryption) caused most of the PCI DSS and GDPR failures. Mapping every finding to a control type and a CSF function made it easier to prioritise and to explain the risk to non-technical stakeholders.